Agente de Terceros (DPAs)

PIMS multiagente basado en ISO/IEC 27701:2025 — revisión asistida de contratos de encargo

Dylan Antonio Zúñiga Huarca Jeferson Joao Basurco Casani Adrian Issac Mamani Quispe

3 de noviembre de 2026

Auditoría de Sistemas · Escuela Profesional de Ingeniería de Sistemas · UNSA

Problema

- Hosting, planillas, pagos, *mailing*: los encargados tratan datos por cuenta nuestra.
- La responsabilidad sigue siendo nuestra; la principal garantía es el contrato de encargo (DPA).
- Revisar cada DPA frente a la LPDP, el RLPDP y el RGPD art. 28 es una tarea manual, lenta y propensa a omisiones.
- Hay que vigilar además vencimientos, subencargados e incidentes.

Contexto peruano

LPDP art. 30: el encargado no puede usar los datos con otro fin y debe suprimirlos al terminar.

RLPDP arts. 28-33: tercerización, encargo y subcontratación.

RLPDP art. 36: el encargado informa de inmediato los incidentes.

El PIMS multiagente y nuestro agente



Controles ISO/IEC 27701:2025: A.1.2.7 contratos con encargados · A.2.5.7 divulgación de subcontratistas · A.2.5.8 contratación de subencargados.

Encargado: Perú frente a la Unión Europea

	Perú (LPDP + RLPDP)	**UE (RGPD)**
Fin limitado	LPDP 30; RLPDP 29.2, 33	Art. 28.3.a, 28.10
Subencargados	Autorización previa; el encargado prueba (RLPDP 32)	Autorización + aviso de cambios (28.2, 28.4)
Incidentes	Informe inmediato (RLPDP 36)	Sin dilación indebida (33.2)
Fin del servicio	Supresión evidenciada; hasta 2 años (RLPDP 30.4, 31.2)	Supresión o devolución (28.3.g)
Transferencias	LPDP 15; RLPDP 12-14	Arts. 44-46

Referencias de buenas prácticas: Directrices 07/2020 del CEPD y cláusulas tipo de la Decisión (UE) 2021/915.

Qué hace el agente

1. Registro de encargados: datos que tratan, sistemas, país y certificaciones.
2. Revisión de DPAs contra 13 cláusulas mínimas, con citas.
3. Riesgo del proveedor: probabilidad $\times$ impacto.
4. Alertas de vencimiento de los DPAs (60 días).
5. Subencargados: todo cambio requiere aprobación.
6. Brechas: ¿qué encargados tratan los datos afectados?

Herramientas MCP

`list_processors`

`check_dpa_status`

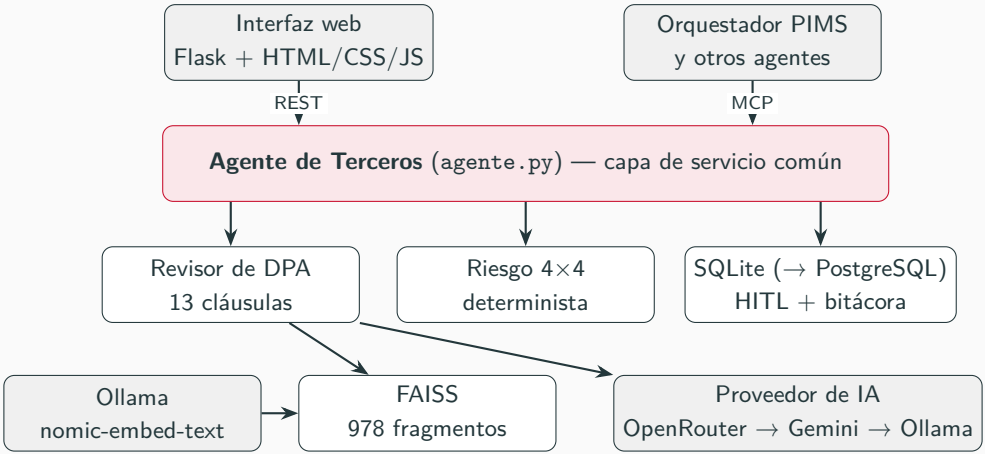
`evaluate_vendor`

`processors_in_breach`

Puerta HITL

Ningún DPA ni cambio de subencargado surte efecto sin la aprobación de Asesoría Legal. Todo queda en la bitácora.

Arquitectura



Las 13 cláusulas mínimas del DPA

- Objeto, duración y finalidad 3
- Instrucciones documentadas 3
- Confidencialidad del personal 2
- Medidas de seguridad 3
- Subencargados: autorización y aviso 3
- Asistencia con los derechos ARCO 2
- Notificación de incidentes 3
- Supresión o devolución al final 3
- Auditorías e inspecciones 2
- Transferencias internacionales 2
- Prohibición de fines propios 3
- Solicitudes de autoridades 1
- Asistencia en la EIPD 1

Cada cláusula está trazada a la LPDP/RLPDP, al RGPD y a ISO/IEC 27701. El número indica su peso: 3 esencial, 2 importante, 1 recomendable.

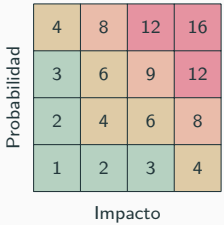
Cómo se revisa un DPA

1. **RAG por cláusula**: 4 fragmentos con la consulta general y 2 peruanos con vocabulario LPDP/RLPDP, ordenados por similitud.
2. **Una sola llamada** al LLM (Gemini 2.5 Flash vía OpenRouter) con las cláusulas, los fragmentos numerados y el contrato → JSON con estado, cita, fundamentos y recomendación.
3. **Verificación literal**: cada frase citada debe existir en el contrato; si no, un *cumple* baja a *parcial*.
4. **Puntaje ponderado**:

$$C = 100\,\frac{\sum_i w_i\, v(e_i)}{\sum_i w_i}, \qquad v(\text{cumple}) = 1,\ v(\text{parcial}) = 0{,}5,\ v(\text{falta}) = 0$$

5. El DPA queda pendiente de aprobación legal.

Riesgo del proveedor: $R = P \times I$



Impacto: volumen de titulares; $+1$ si hay datos sensibles.

Probabilidad: $+1$ por transferencia sin nivel adecuado, subencargados, DPA con $C < 70$ o sin revisar, o sin DPA vigente; $+1/+2$ por incidentes; -1 con ISO/IEC 27701.

Nivel: bajo, medio, alto o crítico, con revisiones cada 24, 12, 6 o 3 meses.

Determinista: el auditor puede reproducir el puntaje.

Del prompt a la skill y al asistente

Prompt suelto "¿este contrato cumple?" → respuestas variables y sin citas.

Proceso reutilizable: 13 cláusulas, RAG, JSON, citas verificadas, puntaje.

Skills (`SKILL.md`)

- Activación: descripción con cuándo usarla
- Estructura: requisitos, referencias, ejemplo
- Pasos: diagnóstico → revisar → informe → aprobación

`revisar-dpa` · `brecha-encargados`

Asistente: Auditor de Encargados (A7)

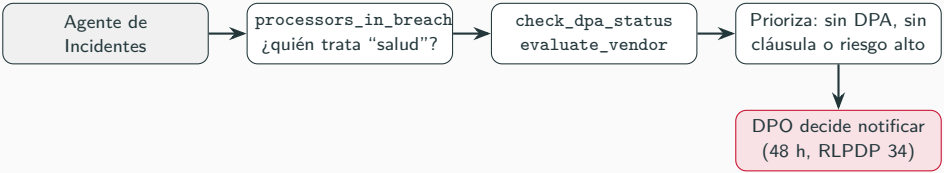
Identidad: rol, objetivo, controles, límites (no aprueba ni notifica).

Instrucciones: prompt de sistema (norma aplicable, citas literales, escalar al DPO).

Conocimiento: 5 normas indexadas, catálogo de cláusulas y controles, matriz de riesgo, base del PIMS.

Orquestación multiagente por MCP

```
uv run agente-terceros orquestar brecha -categoria salud
```



- El servidor MCP del agente se levanta por stdio y otro agente lo usa por JSON-RPC.
- Segundo flujo: `orquestar renovaciones` → tareas por DPAs ausentes, vencidos o por vencer.

Proveedor de IA intercambiable

- OpenRouter por defecto (Gemini 2.5 Flash); también Gemini directo, OpenAI o compatibles, Anthropic y Ollama local.
- Respaldo automático: OpenRouter → Gemini → Ollama.
- Se cambia con `TERCEROS_LLM_PROVIDER` en `.env`.

Control de gasto
Sin tokens de razonamiento · salida limitada · costo registrado · caché por *hash* del prompt.

Una revisión: **US$ 0,0095** en **14,5 s**; repetida: **0,2 s** y gratis.

Evaluación: recuperación normativa

Estrategia (13 cláusulas, k = 6)	Hit@6	MRR	P@6	Cobertura Perú
Solo consulta general	1,000	0,772	0,654	0,154
General + consulta peruana	0,923	0,733	0,538	0,692

- La búsqueda general devuelve casi solo fuentes europeas, más extensas y con el vocabulario del RGPD.
- Primera iteración ("Perú primero", sin ordenar): MRR 0,455 y cobertura peruana 0,308.
- Lección: consultar con el vocabulario propio de cada norma y ordenar los resultados por similitud.

Evaluación: revisión de contratos

Contrato	Ref.	Media	Rango	Exact.
Completo (NubeSegura)	100,0	96,8	93,5–98,4	89,7 %
Intermedio (PagoFácil)	59,7	54,8	54,8–54,8	92,3 %
Deficiente (MailRápido)	17,7	26,3	21,0–30,6	79,5 %

3 contratos $\times$ 13 cláusulas anotados por los autores; 3 corridas por contrato.

Resultados

Exactitud por cláusula: **87,2 %**

Cumple / no cumple: **92,3 %**

Error medio de C: **5,6 pp**

Estabilidad entre corridas: **89,7 %**

Citas verificadas: **98,9 %**

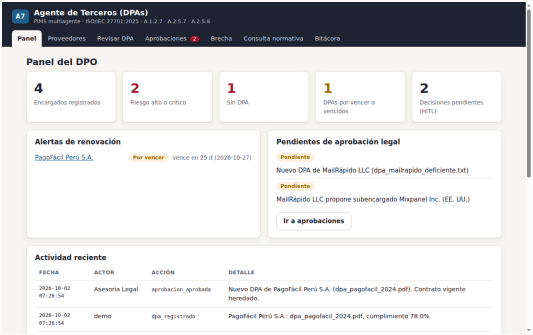
Latencia: **32,0 s**

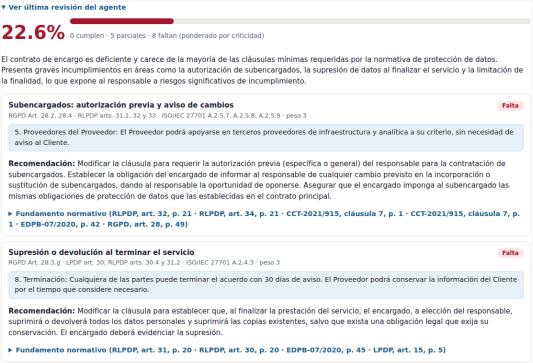
Iteración: la verificación literal en acción

- v1: el modelo a veces parafraseaba la cita → el verificador la rechazaba y bajaba la cláusula a *parcial*.
- Una corrida del contrato completo cayó a 67,7 % (7 de 13 citas rechazadas).
- v2: regla de cita carácter por carácter, con tramos separados por "…".

	v1	v2
Exactitud	84,6 %	87,2 %
Cumple / no	87,2 %	92,3 %
Estabilidad	76,9 %	89,7 %
Error C (pp)	8,1	5,6
Citas verif.	90,8 %	98,9 %

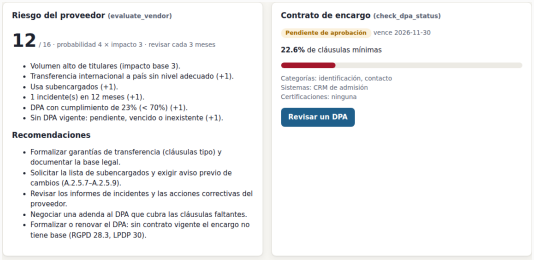
Demostración

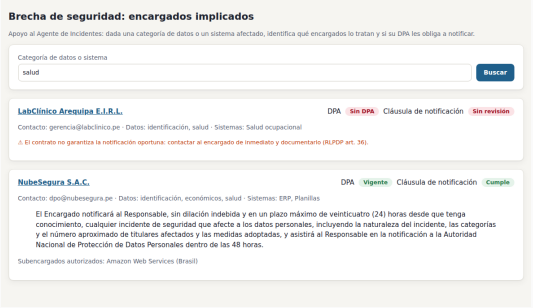




Panel del DPO (alertas y decisiones pendientes) e informe de revisión con citas literales y fundamentos (fuente, artículo, página).

Riesgo, subencargados y brechas





Ficha del proveedor (`evaluate_vendor`, `check_dpa_status`) y encargados implicados en una brecha de datos de salud.

Limitaciones y trabajo futuro

Limitaciones

- Evaluación pequeña (3 contratos, anotados por los autores).
- El LLM no es determinista $\rightarrow$ verificación literal + HITL.
- ISO/IEC 27701:2025 no es de libre acceso: numeración inferida.
- Falta OCR para PDFs escaneados.

Trabajo futuro

- Conectar los flujos MCP con el orquestador definitivo del PIMS y el Agente de Controles.
- Migración a la base PostgreSQL central del PIMS.
- Generación de adendas contractuales.
- Contratos reales anonimizados, anotados con un abogado.

¡Gracias!

github.com/S-kkipie/agente-terceros-dpa